

DevMind Internal Documentation

Security Guidelines and Best Practices — v2.1

1. Application Security Standards

Authentication and Authorization:

All user authentication must use JWT tokens with a maximum expiry of 24 hours. Refresh tokens are valid for 30 days and must be stored in an HttpOnly cookie, never in localStorage. Every API endpoint must verify the token signature before processing any request.

Key rules for authentication implementation:

- Use bcrypt with a minimum cost factor of 12 for password hashing.
- Implement rate limiting on all login endpoints: maximum 5 attempts per minute per IP.
- Enforce multi-factor authentication for all admin and production access.
- Invalidate all sessions immediately upon password change.
- Never log passwords, tokens, or sensitive credentials anywhere.

Input Validation and Sanitization:

Every piece of data entering the system from an external source must be validated and sanitized. This applies to HTTP request bodies, query parameters, headers, file uploads, and database inputs. Never trust client-supplied data.

- Use parameterized queries for all database operations. Never concatenate user input into SQL strings.
- Sanitize all HTML output to prevent Cross-Site Scripting (XSS) attacks.
- Validate file type by inspecting the file header, not the extension.
- Enforce maximum file upload size of 10MB per request.
- Reject requests with unexpected or missing Content-Type headers.

2. Secrets and Credentials Management

Environment Variable Policy:

All secrets, API keys, database credentials, and tokens must be stored in environment variables or a secrets manager such as AWS Secrets Manager. They must never appear in source code, configuration files committed to version control, or application logs.

- Use AWS Secrets Manager for all production credentials.
- Rotate all secrets every 90 days. Critical secrets rotate every 30 days.
- Each service uses its own set of credentials. No shared service accounts.
- Use the principle of least privilege: each secret grants only the minimum required access.
- Run automated secret scanning on every pull request using GitGuardian or equivalent.

Forbidden Practices:

The following actions are strictly prohibited and will result in immediate security incident escalation.

- Committing any secret, token, or password to any Git repository.
- Sharing credentials via Slack, email, or any messaging platform.
- Using production credentials in local development or staging environments.
- Storing secrets in Docker images or Kubernetes ConfigMaps.
- Disabling secret scanning pre-commit hooks.

3. Network and Infrastructure Security

TLS and Encryption:

All communication between services and all client-to-server traffic must be encrypted using TLS 1.2 or higher. TLS 1.0 and 1.1 are deprecated and must not be used. Certificates must be renewed before expiry and monitored with automated alerting.

VPC and Network Isolation:

All production services run inside a private VPC with no direct public internet access. Only the API Gateway and the load balancer have public-facing IP addresses. Database instances must never be placed in a public subnet. Security groups follow the principle of least privilege: only open the ports strictly required.

- Inbound SSH (port 22) is blocked on all production instances. Use AWS Systems Manager Session Manager instead.
- Database ports (5432, 3306, 6379) are accessible only from within the private subnet.
- All outbound traffic from Lambda functions and ECS tasks is routed through a NAT Gateway.

- Enable VPC Flow Logs for all production environments and ship logs to CloudWatch.

4. Incident Response Procedure

Severity Levels:

- SEV-1: Active breach or data exfiltration. Immediate response required 24/7. Escalate to CTO within 15 minutes.
- SEV-2: Vulnerability with active exploitation potential. Response within 4 hours.
- SEV-3: Security misconfiguration without active exploitation. Response within 24 hours.
- SEV-4: Low-risk finding from security scan. Resolved in the next sprint.

Response Steps:

Upon identifying a security incident, the following steps must be executed in order: contain the affected systems immediately, notify the security team via the incident Slack channel, preserve all logs and evidence before making any changes, assess the scope and severity, begin remediation only after containment is confirmed, and document a full post-mortem within 5 business days.

5. Security Review and Compliance

Code Review Security Checklist:

Every pull request that touches authentication, authorization, data handling, or external integrations requires a mandatory security review in addition to the standard code review. The reviewer must verify the following:

- No secrets or credentials are hardcoded or logged.
- All user inputs are validated and sanitized before use.
- SQL queries use parameterized statements.
- Authorization checks are present on every sensitive endpoint.
- Error messages do not expose internal system details to the client.
- Dependencies introduced have no known critical CVEs.

This document is maintained by the Security Team. Last updated: Q2 2025. For questions or to report a vulnerability, contact security@devmind.internal.